

גלישת חוצץ (Buffer Overflow)

מודול 10 — האקינג אתי מהיסוד

◀ זיכרון, Stack ו-Registers

◀ מתודולוגיית 7 השלבים של BOF

◀ Fuzzing → Offset → EIP → Shellcode

◀ ניצול מלא של vulnserver

למה ללמוד Buffer Overflow?

- ◀ הבסיס לכתיבת **Exploits**
- ◀ הבנת Stack, Registers ו-Shellcode
- ◀ ה"טקס מעבר" הקלאסי של **OSCP**
- ◀ מפריד בין "מריץ כלים" ל"מבין"

זיכרון ו-Registers

◀ **EIP** — מצביע להוראה הבאה  המטרה

◀ **ESP** — מצביע לראש ה-Stack

◀ **EBP** — בסיס ה-Frame

◀ מי ששולט ב-EIP — שולט בביצוע

איך נוצרת גלישה?

- ◀ חוצץ בגודל קבוע + קלט **ללא בדיקת אורך**
- ◀ הקלט "גולש" ודורס זיכרון סמוך
- ◀ דורס את כתובת החזרה — **EIP**
- ◀ `strcpy` במקום `strncpy` = הבעיה

מבנה ה-Stack ב-Overflow

◀ [Buffer] — מתמלא ב-A

◀ [Saved EBP] — נדרס

◀ [EIP] ← כאן נשתול **כתובת שלנו**

◀ אחריו: NOPs + Shellcode

סביבת המעבדה

◀ מטרה: **Windows** + `vulnserver.exe`

◀ **Immunity Debugger** + `mona.py`

◀ תוקף: **Kali** (Python, msfvenom)

◀ חלופה: "TryHackMe "Buffer Overflow Prep"

שלב 1-2: Fuzzing ו-Spiking

◀ **Spiking** — איזו פקודה קורסת (TRUN)

◀ **Fuzzing** — שולחים כמות גדלה של A

◀ מוצאים בערך מתי קורס (~2000B)

◀ סקריפט Python פשוט

שלב 3-4: EIP-1 Offset

דפוס ייחודי → `msf-pattern_create -l 3000` ◀

EIP → `msf-pattern_offset` → **2003** קוראים ◀

✓ `EIP = 42424242 → A×2003 + B×4` ◀

הוכחת שליטה מלאה ◀

שלב 5: Bad Characters

- ◀ בתים ש"משבשים" את ה-payload
- ◀ הנפוץ: `\x00` (Null Byte)
- ◀ שולחים `\x01 ... \xff`, משווים ב-mona
- ◀ בית רע שלא זוהה = Shellcode הרוס

שלב 6: JMP ESP

◀ ESP מצביע ל-Shellcode — נקפוץ לשם

◀ `!mona modules` → מודול ללא הגנות

◀ `!mona find -s "\xff\xe4"` → כתובת

◀ `625011AF` :**Little-Endian** → `\xaf\x11\x50\x62`

שלב 7: Shellcode ו-Shell

`msfvenom -p windows/shell_reverse_tcp -b "\x00"` ◀

`Axoffset + JMP ESP + NOPs + Shellcode` :Payload ◀

!Shell → מריצים → `nc -lvp 4444` ◀

NOP Sled = "מרווח נחיתה" בטוח ◀

סיכום 7 השלבים

Spike → Fuzz → Offset → EIP ◀

Bad Chars → JMP ESP → Shellcode ◀

זה בדיוק מה שנבחן ב-OSCP ◀

הגנות מודרניות: ASLR, DEP, Canaries ◀

סיכום מודול 10

◀ BOF = קלט ללא בדיקת אורך → דריסת EIP

◀ שליטה ב-EIP = שליטה בביצוע

◀ 7 שלבים קבועים — שולטים בהם בתרגול

◀ Bad Chars ו-JMP ESP = הנקודות הקריטיות

◀ **תרגול** → `practice.md` · **פתרונות** → `solutions.md`